

You are now a world expert in Cybersecurity research I am trying to get in the mind of an attackers that send phishing messages (SMS and email), I want to know how they think and what tactics they use in order to make the average person fall in their trap.

This topic was already heavily researched and investigated I want you to look for sources that provide the required knowledge as mentioned above.

IMPORTANT - look through a large variety of sources such as but not limited to: academic papers, cybersecurity companies reports, news articles, forums (for people's first hand experience), hacking websites and more. You can add your own input based on your training data but it is important that you mention that. look for sources for both the attacker and defender perspectives.

Your finale answer must be greatly detailed and you must include your sources for further investigation on my side. ^

To understand how a phishing attacker thinks, you have to stop looking at it as a technical problem and start looking at it as a psychological one. Attackers are not trying to hack a device; they are trying to hack the human nervous system.

AwareGO

According to the **2026 Verizon Data Breach Investigations Report (DBIR)**, 62% of all breaches involve the human element. The goal of any modern phishing or smishing (SMS phishing) campaign is to trigger an emotional response that overrides the victim's critical thinking long enough for them to click a link or surrender credentials.

Abnormal AI + 1

Here is a breakdown of the attacker mindset, the psychological triggers they weaponize, and how the landscape has evolved with Generative AI, based on the latest cybersecurity and psychological research.

## The Psychology of the Click

Attackers operate on a biological exploit known as the "Amygdala Hijack." Under acute stress—whether from fear, urgency, or extreme curiosity—the brain’s emotional core takes over, flooding the body with cortisol and adrenaline. Rational, slower decision-making processes are bypassed.

AwareGO + 1

To achieve this state, attackers exploit well-documented cognitive biases:

| Cognitive Bias     | Attacker Tactic                                                                  | Why It Works                                                                                    |
|--------------------|----------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| Authority Bias     | Impersonating a CEO, the IRS, or the FBI.                                        | Humans are conditioned to comply with authority figures without questioning them.               |
| Scarcity / Urgency | "Your account will be suspended in 1 hour."                                      | Creates a fear of missing out or a fear of loss, forcing an immediate, impulsive reaction.      |
| Social Proof       | Business Email Compromise (BEC) referencing real ongoing projects or colleagues. | If it looks like other trusted people are involved in the thread, the victim drops their guard. |
| Optimism Bias      | "You've won a gift card" or "Exclusive insider info."                            | The universal belief that "bad things happen to other people, but good things happen to me."    |

...



*Cognitive biases frequently exploited in phishing. Source: KnowBe4 Blog*

## Why Attackers are Pivoting to SMS (Smishing)

If you are analyzing SMS content, you are looking at the fastest-growing attack vector. The **Zimperium 2025 Global Mobile Threat Report** notes that 69.3% of all mobile-targeted phishing attacks are now SMS-based.

Vectra AI

Attackers love SMS for three distinct reasons:

- Intimacy and Trust:** People treat their SMS inbox as a private, highly curated space. We instinctively trust a text more than an email.  
The Decision Lab
- Immediate Attention:** Texts generate push notifications that demand immediate attention, perfectly aligning with the "urgency" bias.  
The Decision Lab
- Bypassing Corporate Filters:** Employees frequently check personal texts on corporate devices. A smishing text bypasses enterprise email gateways entirely, delivering a malicious payload straight to an authenticated endpoint.

Attackers frequently use URL shorteners (like bit.ly) or visually similar domains (homograph attacks) in texts because mobile phone screens truncate long URLs, making them harder to visually inspect.

CrowdStrike

## The Generative AI Era: Flawless and Polymorphic

Historically, defenders relied on bad grammar, spelling mistakes, and generic greetings ("Dear Customer") to spot phishing. That era is definitively over.

CrowdStrike

Large Language Models (LLMs) have reduced the time needed to create a highly convincing, context-aware phishing campaign from roughly 16 hours to about five minutes. According to **Zensec's 2025-2026 Phishing Statistics**, 82.6% of phishing emails detected recently utilized AI, resulting in a 60% higher click rate than traditionally crafted lures.

Zensec

Attackers now employ **polymorphic phishing**—using AI to dynamically alter the phrasing, sender information, and structure of every single message in a mass campaign while retaining the core malicious payload. This renders traditional static signature-based detection (which looks for exact matches of known bad text) almost useless.

## The Defender's Playbook: What to Look For Now

Because attackers have perfected the grammar and scaled the personalization, defenders must shift from looking for *static indicators of compromise (IOCs)* to looking for *behavioral anomalies*.

Abnormal AI

When analyzing message phrasing to detect a threat, the focus shifts to linguistic intent:

- **The Request:** Is the message asking for a credential, a financial transaction, or a payload download?
- **The Tone:** Does the text artificially manufacture urgency or authority?

Vectra AI

- **The Context:** Is the communication pattern abnormal for this sender?

Defenders are increasingly utilizing their own LLMs to analyze the semantic meaning of incoming messages, looking for these psychological manipulation tactics rather than just scanning for known malicious links.

## Sources for Further Investigation

1. **Verizon 2026 Data Breach Investigations Report (DBIR):** The gold standard for understanding attack vectors and the prevalence of the human element in breaches.  
Verizon
2. **Zimperium 2025 Global Mobile Threat Report:** Crucial for data on the rise of mobile-targeted smishing attacks.  
Vectra AI
3. **"Smishing: Exploring How Different Persuasion Techniques Influence Users Emotions, Cognitions, and Identification Accuracy" (El Shamy et al., 2025):** An academic paper exploring the neurophysiological responses to SMS phishing.  
IDEAS/RePEc
4. **"Human Cognition Through the Lens of Social Engineering Cyberattacks" (PMC):** Academic research detailing how high cognitive workload and stress make users susceptible to these attacks.  
PMC - NIH
5. **Zensec Phishing Statistics 2025–2026:** Provides hard data on the adoption of AI and polymorphic generation by threat actors.  
Zensec

Want to explore how to build linguistic anomaly detection for SMS?

↪ Yes

CONTEXT - my final goal is to send the message to a LLM along with additional instructions on what patterns should it look for in the text.  
Answer the first prompt again with the context in mind

If your goal is to feed this psychological framework into an LLM to scan incoming messages for malicious intent, you need to translate human cognitive biases into machine-readable heuristics.

An LLM shouldn't just be asked, "Is this phishing?" It needs to act as a linguistic anomaly detector, breaking down the syntax, intent, and emotional payload of a message—especially given the extreme brevity of SMS.

Here is how the attacker's mindset translates directly into specific instructions and pattern-matching criteria for your LLM.

## Translating Attacker Psychology into LLM Heuristics

To force the victim into making a mistake, attackers engineer their phrasing to bypass logical thought. Your LLM needs to be instructed to look for the combination of these emotional triggers alongside a specific structural anomaly (like an obfuscated link).

| Attacker Tactic / Bias | How it Appears in Text                                                  | Instructions for the LLM                                                                                                                                       |
|------------------------|-------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Urgency / Scarcity     | "Action required immediately,"<br>"Your account will be locked in 24h." | <b>Identify Time Bounds:</b> Instruct the LLM to extract any temporal deadlines tied to a negative consequence.                                                |
| Authority Bias         | "IRS Final Notice," "Message from CEO."                                 | <b>Entity Extraction:</b> Have the LLM flag when a message claims to be from a high-authority entity but originates from a casual or mismatched sender format. |

Attacker Tactic / Bias

How it Appears in Text

Instructions for the LLM

Optimism / Greed

"Your package is ready,"  
"You've been selected for a  
refund."

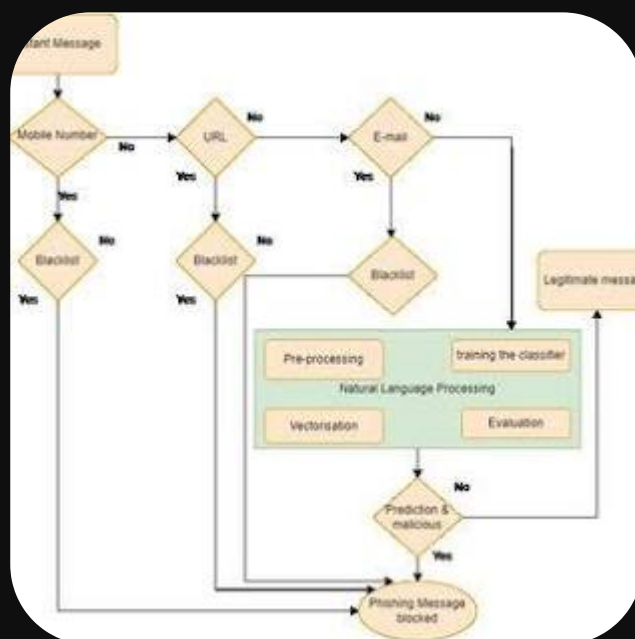
**Unsolicited Reward:** Instruct  
the LLM to flag sudden,  
unprompted positive  
outcomes that require a click  
to claim.

Familiarity / Trust

"Hey it's me, my phone broke,"  
"Are we still on for later?"

**Contextual Disconnect:** Have  
the LLM analyze if the  
message implies a prior  
relationship but demands  
immediate financial action  
(e.g., Apple Pay request).

...



*NLP pipeline for SMS phishing detection.*

Source: ResearchGate

## What the LLM Must Look For: Structural Anomalies

Attackers know defenders are using automated scanners, so they actively try to break regex and static filters. Your LLM prompt must be instructed to look for these specific evasion tactics, particularly in SMS where character limits force attackers to be creative.

## 1. Intent vs. Destination Mismatch

The LLM must analyze the "Call to Action" (CTA). If the message claims to be from a major bank (e.g., Chase) but the CTA directs the user to a generic URL shortener ( `bit.ly`, `tinyurl` ) or an IP address, the LLM should heavily weight this as malicious. Legitimate enterprise SMS systems rarely use third-party shorteners due to brand trust issues.

## 2. Linguistic Obfuscation

Attackers use zero-width spaces, homoglyphs (using Cyrillic 'a' instead of Latin 'a'), or erratic punctuation to bypass standard filters (e.g., `P.α.y.P.α.l` or `b@nk` ).

- **LLM Instruction:** "Analyze the text for intentional misspellings, excessive special characters, or unnatural spacing designed to disguise brand names."

## 3. The "Action-Required" Payload

Phishing almost always requires the user to *do* something.

- **LLM Instruction:** "Determine if the core intent of this message is to elicit a credential, force a download, or trigger a financial transfer. Isolate the exact sentence making this request."

## Prompt Architecture Strategy

To get the most accurate results, structure your prompt as a "Chain of Thought" analysis. Do not ask for a simple True/False.

1. **Extract:** "Identify the sender claim, the emotional trigger, and the required user action."
2. **Analyze:** "Does the requested action logically match the sender's identity and the urgency presented?"
3. **Evaluate:** "Are there signs of linguistic evasion or obfuscated links?"
4. **Score:** "Provide a confidence score (0-100) that this is a social engineering attempt, along with the reasoning."



# Sources for System Design & LLM Integration

When designing the backend logic for this system, look into these resources:

- **"Detecting Phishing Sites Using ChatGPT" (Cornell University/arXiv, 2024):** Academic papers on arXiv detail exact prompt engineering techniques used to train LLMs for classifying malicious text and URLs.
- **"A Comprehensive Survey on Smishing Attacks and Detection Techniques" (IEEE Xplore):** Breaks down the specific datasets and machine learning features (like URL length, presence of action verbs) historically used to detect malicious SMS.
- **Google Project Zero & Threat Analysis Group (TAG) Reports:** Excellent for understanding the state-of-the-art evasion techniques attackers are currently using in the wild, which you can then reverse-engineer into your LLM prompts.
- **PhishTank / APWG (Anti-Phishing Working Group):** These databases provide raw, real-world examples of current phishing campaigns. You should feed these into your LLM during testing to refine its detection capabilities.

Want to see an example of a system prompt designed for this?

↔ Yes